

Redes de Ordenadores

GII – IYA022

Fundamentos de Seguridad en Redes de Ordenadores

Mariano Benito

- Introducción
 - Concepto de seguridad
 - Características de la información
 - Conceptos básicos
- Ataque
 - Taxonomía
 - Ejemplos de ataques
- Seguridad en la red
 - Seguridad en el diseño de redes
 - Configuración y actualización de los dispositivos de red
 - Enrutadores, cortafuegos y servidores *proxy*
 - Zona desmilitarizada (DMZ)
 - Detección y prevención de intrusiones
 - Seguridad en redes inalámbricas
- Políticas de seguridad
 - Gestión y respuesta a incidentes
 - Cadena de información
 - Plan de contingencia y continuidad de negocio
 - Evidencias digitales y cadena de custodia

- Conocer los **principios fundamentales de la seguridad** en redes de ordenadores.
- Comprender el concepto de **ataque**.
- Comprender posibles **mejoras de la seguridad mediante el diseño de redes**.
- Conocer los **principales dispositivos implantables** en una red para mejorar su seguridad.
- Conocer la existencia y el objetivo de **políticas de seguridad**.

- La **seguridad** es el **estado de estar libre de peligro** y su principal objetivo es la **protección frente a adversarios** que puedan causar daño, ya sea de manera **intencionada o accidental**.
- ISO 27000: La **seguridad de la información** es la **preservación de la confidencialidad, integridad y disponibilidad** de la información e implica la **aplicación y gestión de controles adecuados** con el objetivo de **asegurar la continuidad y el éxito sostenido del negocio**, así como **minimizar las consecuencias de los incidentes**.

Áreas de **seguridad** que protegen las operaciones de una organización:



Física

Protege **objetos, elementos y áreas**

Mediante:

- control de acceso
- videovigilancia
- contra desastres naturales



Personal

Protege **a las personas autorizadas**

Mediante:

- verificación de antecedentes
- concienciación y formación
- gestión de privilegios de acceso



Operacional

Protege **los procesos y la continuidad del negocio**

Mediante:

- procedimientos de trabajo seguros
- gestión de la información sensible



de las Comunicaciones

Protege **los medios y el contenido transmitido**

Mediante:

- cifrado
- autenticación de los actores
- integridad de los mensajes
- protegiendo los canales



de Red

Protege **los componentes y el contenido que circula**

Mediante:

- cortafuegos
- IDS e IPS
- diseños seguros
- monitorización y registro de la actividad



de la Información

Protege **los activos de información**

Mediante:

- control de acceso
- gestión de credenciales
- cifrado
- backups
- planes de recuperación

- **Confidencialidad:** asegura que la información está **protegida frente a la divulgación o exposición** a personas, dispositivos o sistemas no autorizados, **garantizando que solo quienes tienen los derechos y privilegios necesarios pueden acceder a ella.**
- **Posibles medidas:**
 - Autenticación de usuarios (preferiblemente multifactor).
 - Gestión de privilegios basado en roles.
 - Almacenamiento seguro.
 - Cifrado de datos.
 - Clasificación de la información.
 - Formación del personal que custodia la información.
- **@Redes:** asegurar que **los datos transmitidos** por la red **no sean interceptados, alterados ni leídos por terceros** no autorizados.

- **Integridad:** asegura que la información está **entera, completa y que no ha sido corrompida, garantizando que esta no ha sido modificada de manera no autorizada o indeseable.**
 - Cambio o eliminación de parte o la totalidad de la información:
 - No autorizado → tener los medios para evitar cambios no autorizados ...
 - Autorizado, pero no deseable → ... y revertir los que no se tenían que haber realizado.
 - **Posibles medidas:**
 - Funciones *hash* criptográficas.
 - Firmas digitales.
 - Códigos de autenticación de mensajes.
 - Sistemas de control de versiones y auditoría de cambios.
 - **@Redes:** asegurar que **esta no ha sido corrompida durante su transmisión.**

- **Disponibilidad:** asegura el acceso de los usuarios (personas o dispositivos), a los sistemas e información cuando sea necesario.
 - Incluye la capacidad de mantener en funcionamiento los servicios incluso ante fallos o ataques. → acuerdos de nivel de servicio (SLA).
 - **Posibles medidas:**
 - Redundancia de sistemas y datos.
 - Balanceadores de carga.
 - Planes de recuperación ante desastres.
 - Monitorización continua de los servicios.
 - **@Redes:** asegurar la ausencia de interrupciones en cualquier parte de la cadena de comunicaciones que permite la interacción con los sistemas que ofertan la información como un recurso y que dichas comunicaciones no sean denegadas por ausencia de recursos.

- **Exactitud:** asegura **que la información es precisa** (está libre de errores o equivocaciones), **y posee el valor que el usuario final espera, garantizando que la información no ha sido modificada**, ya sea de forma intencionada o accidental.
- **@Redes:** esta puede comprometerse cuando **la información no puede transmitirse en el formato necesario para preservar el valor exacto** que pretende representar.

- **Autenticidad:** asegura **que la información es genuina y proviene de la fuente declarada**, manteniéndose el mismo estado en el que fue creada, almacenada o transmitida, **garantizando la autoría de los datos y evitando que sean falsificados o manipulados por terceros** no autorizados.
 - Se relaciona con el **principio de no repudio** → impide que una persona niegue haber realizado una acción particular.
- **Posibles medidas:**
 - Firmas y certificados digitales.
 - Protocolos de autenticación segura.
- **@Redes:** esta **puede comprometerse mediante técnicas como el *spoofing* o el *phishing***, donde se engaña al usuario simulando fuentes legítimas para obtener información confidencial.

- **Utilidad:** asegura **que la información tiene valor para un propósito o finalidad concreta.**
 - Una información es útil cuando está disponible y en un formato comprensible y relevante para el usuario final.
- **Posibles medidas:**
 - Empleo de formatos estándar.
- **@Redes:** esta **puede comprometerse cuando la información transmitida no puede ser procesada correctamente por el receptor**, ya sea por incompatibilidad de formatos o codificación incorrecta.

- **Posesión:** asegura la propiedad o control sobre los datos, independientemente del formato o su contenido.
 - Una entidad tiene posesión cuando obtiene la información, aunque no necesariamente tenga acceso a su contenido.
 - Por ejemplo: porque el contenido está cifrado y se desconoce la clave de acceso.
- Una brecha en la **confidencialidad** siempre implica una brecha en la **posesión**, pero no siempre al revés.
- **@Redes:** comprometer la posesión implica la pérdida de control físico o lógico sobre la información, como el robo de dispositivos o la captura de la información que está siendo transmitida por la red.

- **Amenaza:** es una **acción o evento que puede causar un perjuicio a la organización** como la violación, interrupción o corrupción de un sistema, **aprovechando vulnerabilidades** conocidas o desconocidas.
- Se clasifican en:
 - **Accidentales:** eventos naturales (tormentas, inundaciones, cortes de energía, ...), fallos inesperados en el HW, errores de SW, errores humanos.
 - **Deliberadas:** aquellas que resultan de ataques intencionados.
- **Activo:** es **cualquier recurso**, ya sea informático o no, **que es necesario para que una organización pueda alcanzar sus objetivos** → todo aquello que posee valor y debe ser protegido.
 - Por ejemplo: los trabajadores, el software, los datos, los archivos, el hardware y las redes y medios de comunicación de la organización.

- **Vulnerabilidad** (“agujero de seguridad”): es cualquier **fallo presente** en un activo, sistema, red o proceso **que puede ser explotado para comprometer información o el funcionamiento de un sistema informático**. Pueden deberse a errores de diseño, fallos en la implementación, configuraciones incorrectas o falta de actualizaciones y **representan un punto débil donde una amenaza puede materializarse**.
- **Riesgo**: es la **estimación del grado de exposición que tiene un activo o conjunto de activos frente a la materialización de una amenaza**.
- **Impacto**: es la **consecuencia** que sufre una organización **cuando se produce un incidente → alcance del daño causado** cuando una amenaza se materializa.

- Es una **acción deliberada o accidental que busca explotar una vulnerabilidad** en un sistema para comprometer su seguridad, causar daño o tomar control de este.
 - A diferencia de las amenazas, que son condiciones o factores que siempre están presentes, **los ataques se materializan solo cuando se realiza una acción concreta que puede ocasionar un impacto.**

- **Taxonomía: clasificar y etiquetar los ataques es fundamental** para comprender mejor las amenazas, anticiparse a ellas, y diseñar mecanismos de defensa efectivos. Además, permite organizar los ataques según sus características, objetivos, técnicas empleadas y efectos sobre los sistemas, permitiendo y facilitando:
 - Mejorar la detección temprana y la respuesta.
 - Identificar patrones de ataque.
 - Priorizar recursos para la defensa y mitigación.
 - Desarrollar planes de respuesta y recuperación.
 - Facilitar la formación y sensibilización de usuarios.
 - Promover la colaboración y compartición de información.
- **MITRE ATT&CK** permite mapear cada acción del atacante a una **táctica** (objetivo de alto nivel) y una **técnica** (el método empleado), **pudiendo determinar en qué fase se encuentra el ataque detectado y actuar en consecuencia**. Asimismo, permite desarrollar reglas para configurar sistemas, ayudar en la respuesta a incidentes y simular escenarios para entrenar y proteger infraestructuras.

Tácticas (objetivo de alto nivel)

Técnicas (método empleado)

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
11 techniques	8 techniques	11 techniques	17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques
- Active Scanning (3) - Gather Victim Host Information (4) - Gather Victim Identity Information (3) - Gather Victim Network Information (6) - Gather Victim Org Information (4) - Phishing for Information (4) - Search Closed Sources (2) - Search Open Technical Databases (5) - Search Open Websites/Domains (3) - Search Threat Vendor Data - Search Victim-Owned Websites	- Acquire Access - Acquire Infrastructure (8) - Compromise Accounts (3) - Compromise Infrastructure (8) - Develop Capabilities (4) - Establish Accounts (3) - Obtain Capabilities (7) - Stage Capabilities (6)	- Content Injection - Drive-by Compromise - Exploit Public-Facing Application - External Remote Services - Hardware Additions - Phishing (4) - Replication Through Removable Media - Supply Chain Compromise (3) - Trusted Relationship - Valid Accounts (4) - Wi-Fi Networks	- Cloud Administration Command - Command and Scripting Interpreter (13) - Container Administration Command - Deploy Container - ESXi Administration Command - Exploitation for Client Execution - Input Injection - Inter-Process Communication (3) - Native API - Poisoned Pipeline Execution - Scheduled Task/Job (5) - Serverless Execution - Shared Modules - Software Deployment Tools - System Services (3) - User Execution (5) - Windows Management Instrumentation	- Account Manipulation (7) - BITS Jobs - Boot or Logon Autostart Execution (14) - Boot or Logon Initialization Scripts (5) - Cloud Application Integration - Compromise Host Software Binary - Create Account (3) - Create or Modify System Process (5) - Event Triggered Execution (18) - Exclusive Control - External Remote Services - Hijack Execution Flow (12) - Implant Internal Image - Modify Authentication Process (9) - Modify Registry - Office Application Startup (6) - Power Settings - Pre-OS Boot (5) - Scheduled Task/Job (5) - Server Software Component (6) - Software Extensions (2)	- Abuse Elevation Control Mechanism (6) - Access Token Manipulation (5) - Account Manipulation (7) - Boot or Logon Autostart Execution (14) - Boot or Logon Initialization Scripts (5) - Create or Modify System Process (5) - Domain or Tenant Policy Modification (2) - Escape to Host - Event Triggered Execution (18) - Exploitation for Privilege Escalation - Hijack Execution Flow (12) - Process Injection (12) - Scheduled Task/Job (5) - Valid Accounts (4) - Indicator Removal (10) - Masquerading (12) - Modify Authentication Process (9) - Modify Cloud Compute Infrastructure (5) - Modify Cloud Resource Hierarchy - Modify Registry	- Abuse Elevation Control Mechanism (6) - Access Token Manipulation (5) - BITS Jobs - Build Image on Host - Debugger Evasion - Delay Execution - Deobfuscate/Decode Files or Information - Deploy Container - Direct Volume Access - Domain or Tenant Policy Modification (2) - Email Spoofing - Execution Guardrails (2) - Exploitation for Defense Evasion - File and Directory Permissions Modification (2) - Hide Artifacts (14) - Hijack Execution Flow (12) - Impair Defenses (12) - Impersonation - Indicator Removal (10) - Indirect Command Execution - Masquerading (12) - Modify Authentication Process (9) - Modify Cloud Compute Infrastructure (5) - Modify Cloud Resource Hierarchy - Modify Registry	- Adversary-in-the-Middle (4) - Brute Force (4) - Credentials from Password Stores (6) - Exploitation for Credential Access - Forced Authentication - Forge Web Credentials (2) - Input Capture (4) - Modify Authentication Process (9) - Multi-Factor Authentication Interception - Multi-Factor Authentication Request Generation - Network Sniffing - OS Credential Dumping (8) - Steal Application Access Token - Steal or Forge Authentication Certificates - Steal or Forge Kerberos Tickets (5) - Unsecured Credentials (8)	- Account Discovery (4) - Application Window Discovery - Browser Information Discovery - Cloud Infrastructure Discovery - Cloud Service Dashboard - Cloud Service Discovery - Cloud Storage Object Discovery - Container and Resource Discovery - Debugger Evasion - Device Driver Discovery - Domain Trust Discovery - File and Directory Discovery - Group Policy Discovery - Local Storage Discovery - Log Enumeration - Network Service Discovery - Network Share Discovery - Network Sniffing - Password Policy Discovery - Peripheral Device Discovery - Permission Groups Discovery (3) - Process Discovery - Query Registry - Remote System Discovery - Software Discovery (2) - System Information Discovery	- Exploitation of Remote Services - Internal Spearphishing - Lateral Tool Transfer - Remote Service Session Hijacking (2) - Remote Services (8) - Replication Through Removable Media - Software Deployment Tools - Taint Shared Content - Use Alternate Authentication Material (4)	- Adversary-in-the-Middle (4) - Archive Collected Data (3) - Audio Capture - Automated Collection - Browser Session Hijacking - Clipboard Data - Data from Cloud Storage - Data from Configuration Repository (2) - Data from Information Repositories (6) - Data from Local System - Data from Network Shared Drive - Data from Removable Media - Data Staged (2) - Email Collection (3) - Input Capture (4) - Screen Capture - Video Capture	- Application Layer Protocol (5) - Communication Through Removable Media - Content Injection - Data Encoding (2) - Data Obfuscation (3) - Dynamic Resolution (3) - Encrypted Channel (2) - Fallback Channels - Hide Infrastructure - Ingress Tool Transfer - Multi-Stage Channels - Non-Application Layer Protocol - Non-Standard Port - Protocol Tunneling - Proxy (4) - Remote Access Tools (3) - Traffic Signaling (2) - Web Service (3)	- Automated Exfiltration (1) - Data Transfer Size Limits - Exfiltration Over Alternative Protocol (3) - Exfiltration Over C2 Channel - Exfiltration Over Other Network Medium (1) - Exfiltration Over Physical Medium (1) - Exfiltration Over Web Service (4) - Scheduled Transfer - Transfer Data to Cloud Account	- Account Access Removal - Data Destruction (1) - Data Encrypted for Impact - Data Manipulation (3) - Defacement (2) - Disk Wipe (2) - Email Bombing - Endpoint Denial of Service (4) - Financial Theft - Firmware Corruption - Inhibit System Recovery - Network Denial of Service (2) - Resource Hijacking (4) - Service Stop - System Shutdown/Reboot

- **Sniffing**: consiste en la **captura y análisis de los datos transmitidos por la red** en tiempo real mediante *sniffers* (*Wireshark*). Tienen aplicaciones legítimas en el diagnóstico de problemas, pero su uso no autorizado es especialmente peligroso porque son prácticamente indetectables.
 - Los sistemas y usuarios están en riesgo cuando transmiten datos sin cifrar.
 - Es una técnica frecuente para vulnerar la → **confidencialidad**.

- **Spoofing**: consiste en la **suplantación de la identidad** de un dispositivo para obtener acceso no autorizado, engañar a usuarios o sistemas o interceptar y manipular comunicaciones. Esta suplantación puede afectar diversas capas y diferentes protocolos, siendo los más comunes:
 - **IP spoofing**: consiste en manipular la cabecera IP de los datagramas, ya sea para evadir controles de acceso haciéndose pasar por un equipo confiable, lanzar ataques de denegación de servicio, o redirigir tráfico.
 - Muchos de los *routers* o *firewalls* actuales implementan filtro *anti-spoofing* que verifican la legitimidad de las direcciones IP.
 - **ARP spoofing** (*ARP poisoning*): consiste en enviar mensajes ARP falsificados para asociar la dirección MAC del atacante con la dirección IP de otro equipo (p. ej.: la puerta de enlace) para interceptar, modificar o bloquear el tráfico de la red local convirtiéndose en un *man-in-the-middle*.
 - **DNS spoofing**: consiste en alterar las respuestas del servidor DNS para redirigir a los usuarios a sitios falsos o maliciosos sin que ellos lo sepan.

- ***Man-in-the-Middle (MitM)***: consiste en que un atacante intercepta y manipula las comunicaciones entre dos partes sin que estas lo detecten mediante la captura y posterior modificación o fabricación de nuevos paquetes de red.
 - Se emplea *IP spoofing* para suplantar la identidad de uno de los interlocutores en la comunicación.
 - Ej. peligroso: **interceptación de intercambios de claves de cifrado**, lo que permite al atacante actuar como un hombre invisible en el medio de una comunicación cifrada, logrando descifrar y (modificar) los mensajes sin que los usuarios legítimos se percaten.
 - Comprometen la **confidencialidad**, la **integridad** y la **autenticidad** de la comunicación.

- ***(Distributed) Denial-of-service ((D)DoS)***: consiste en la **saturación de un sistema mediante el envío de un gran número de solicitudes de conexión o de mensajes especialmente diseñados para que ejecute procesos costosos** → provocando que el sistema objetivo se sobrecargue y no pueda responder a las solicitudes legítimas de servicio efectuadas por otros usuarios, desencadenando su caída o la incapacidad para desempeñar sus funciones habituales.
- **En el ataque distribuido (DDoS), la avalancha de solicitudes coordinadas proviene simultáneamente de múltiples ubicaciones** que previamente han sido comprometidas para formar una **botnet**.
 - Los ataques DDoS son especialmente difíciles de mitigar ya que no existe ninguna medida única que una organización pueda aplicar para bloquearlos → **existen servicios especializados y esfuerzos cooperativos entre proveedores de servicios** para mitigar este tipo de ataques.
- Cualquier sistema conectado a Internet que ofrezca servicios basados en TCP (web, ftp, mail, ...) es vulnerable a este tipo de ataques. Además, también pueden dirigirse a dispositivos de red empleando otros protocolos como ICMP para el ataque.

- La red de una organización puede ser protegida empleando múltiples vías y recursos:
 - Mediante **diseños de red** inherentemente **seguros** y resistentes a ataques o contratiempos técnicos.
 - Implantando dispositivos en los límites de la red (**seguridad perimetral**).
 - Implantando dispositivos dentro de la red para **monitorizar y controlar el tráfico**.
 - Implantando **dispositivos que detecten comportamientos anómalos o actividades maliciosas** (IDS / IPS).
 - Implementando **sistemas de autenticación y cifrado**.
 - Mediante el uso de túneles que permitan transportar la información de forma segura a través de redes inseguras.
 - Haciendo uso de listas de control de acceso (ACLs).
 - **Configuración y actualización adecuada de los dispositivos.**

1. **Segmentación:** la red se divide en múltiples redes más pequeñas, llamadas subredes, permitiendo acotar el espacio potencial de un ataque. El flujo de tráfico entre subredes se puede controlar, permitiéndolo o rechazándolo, en función de una variedad de factores.
 - Asimismo, su granularidad se puede extender hasta el nivel de cargas de trabajo individuales o por proyectos → **microsegmentación**.
 - Además, esta segmentación permite aumentar el rendimiento de la red y ayuda en la localización de problemas técnicos.
2. **Canalización del tráfico** de la red a través de ciertos dispositivos donde puede ser **inspeccionado, filtrado y controlado**, como enrutadores, cortafuegos o servidores *proxy*.
3. **Redundancia:** cuando un cierto ataque o problema técnico hace inutilizable una parte de la red y/o ciertos dispositivos o componentes, un diseño que haya planificado que algunos dispositivos fallen, permite que la red siga funcionando, aunque no sea al 100% de sus capacidades.

- **Establecer contraseñas robustas** en todos los dispositivos.
- **Actualizar el *firmware* de los dispositivos**, ya que aplicar los parches de seguridad disponibles reduce drásticamente la exposición a vulnerabilidades conocidas.
- Implementación de un **sistema de control de acceso basado en roles** (niveles de privilegios) junto con un mínimo nivel de auditoría de accesos.
 - **Cada administrador** tiene que contar con **credenciales propias** y permisos ajustados a sus responsabilidades → **principio de privilegio mínimo**.
- **La exposición de puertos y servicios debe controlarse**, habilitando únicamente los requeridos y en versiones seguras.
- **Restringir el acceso a interfaces de administración** mediante ACLs o filtros por dirección IP y/o MAC.

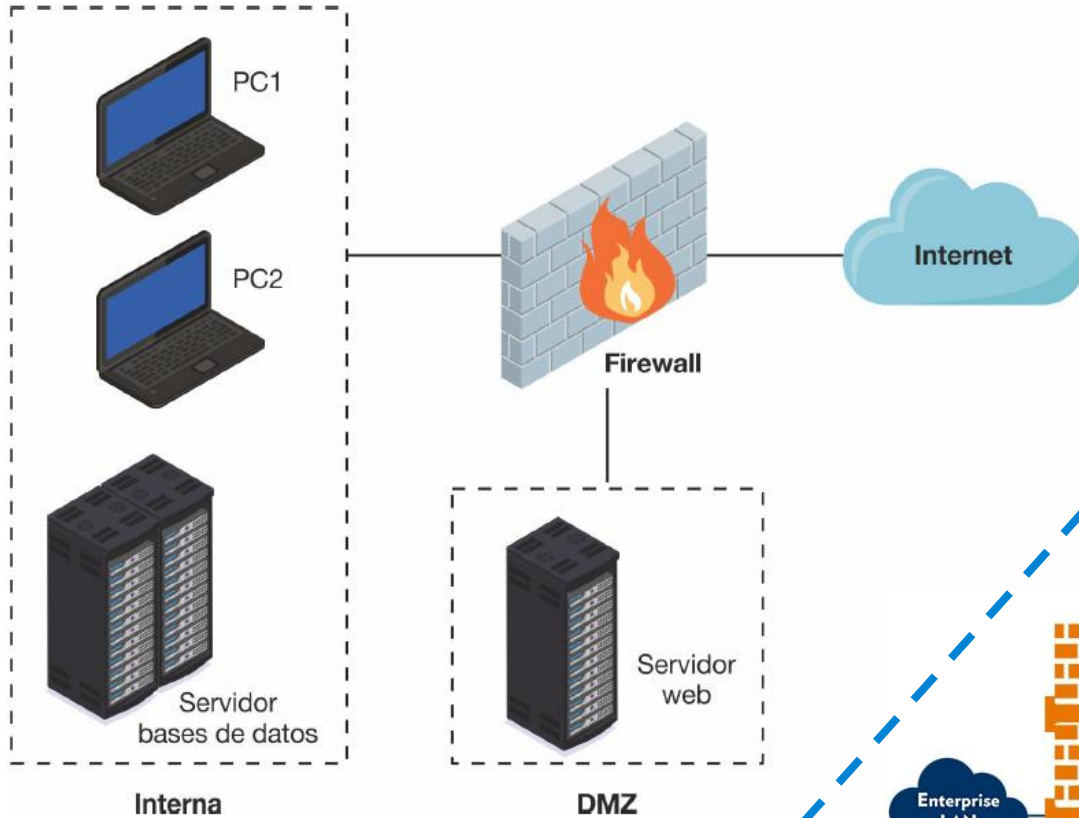
- Los *routers* pueden cumplir un papel en la seguridad de la red:
 - **Permiten el uso de** listas de control de acceso (**ACLs**) con las que definir reglas explícitas para permitir o denegar paquetes en función de criterios como la dirección IP de origen y/o destino, el protocolo o el puerto. Así, el *router* puede actuar como un filtro de tráfico que limite la propagación lateral de ataques.
 - La traducción de direcciones (**NAT**) **permite ocultar las direcciones IP de una red al comunicarse con dispositivos de otra**. Habitualmente, esto se emplea para proteger las direcciones IP privadas cuando se comunican con Internet pero puede ser usado entre dos redes privadas.
- **El uso combinado de NAT con ACLs y segmentación permite construir perímetros de seguridad robustos**, lo que limita el tráfico entrante no solicitado y refuerza el aislamiento de los sistemas internos frente a amenazas externas.

- Un *firewall* **controla el tráfico entre diferentes zonas de confianza, permitiendo o denegando las comunicaciones** según un conjunto de reglas previamente definidas.
 - Pueden ser dispositivos dedicados, software instalado en un servidor o estar integrados en los *routers*.
 - Típicamente se despliegan entre la red privada e Internet, y actúan como primera línea de defensa en la arquitectura de seguridad perimetral, aunque también pueden ser desplegados internamente para segmentar zonas críticas de la red, lo que permite contener movimientos laterales.
- Tipos:
 - **Filtrado de paquetes sin estado:** cada paquete es inspeccionado sin tener en cuenta su contexto dentro de un flujo.
 - **Cortafuegos con inspección de estado:** mantienen una tabla de conexiones activas y verifican si un paquete pertenece a una sesión existente o inicia una nueva permitiendo mayor contexto y control para bloquear conexiones inesperadas o no autorizadas.
 - **Cortafuegos con inspección profunda de paquetes** (*Deep Packet Inspection*, DPI): analizan también el contenido de los paquetes. Aunque son muy potentes, estos dispositivos pueden generar problemas de privacidad y rendimiento.
- Existen dos métodos de configuración de un cortafuegos:
 - **Principio de privilegio mínimo:** **todo lo que no está explícitamente permitido está prohibido** → requiere una definición exhaustiva de las comunicaciones legítimas y se sostiene en el uso de reglas restrictivas que proporcionan una mayor seguridad.
 - **Permisivo:** **todo lo que no está explícitamente prohibido está permitido** → facilita la administración inicial, es más flexible y definitivamente menos seguro.

- También llamados **firewalls de aplicación** o de **capa 7**, los **proxies** actúan como intermediaries entre el origen y el destino de un flujo (mayoritariamente HTTP(S)) **analizando el contenido completo de la comunicación en ese nivel**. Esto les permite entender la lógica del protocolo utilizado y detectar amenazas específicas del tráfico de cada servicio.
 - No pueden verse como un sustituto del FW perimetral sino como un complemento.
 - También pueden ser usados como **proxy inverso**, lo que refuerza la seguridad perimetral de aplicaciones web expuestas a Internet.

- **Es una subred diseñada para exponer servicios (web, correo, DNS, ...) en redes no confiables como Internet, mientras se protege la red interna de la organización.**
 - El diseño habitual de una DMZ implica el uso de **uno o más FW que controlan de forma estricta qué tráfico puede entrar o salir de esta zona**, y limita así el riesgo de que un atacante obtenga el acceso a toda la red de la organización tras comprometer un servicio en la DMZ.
 - La configuración de los servidores en la DMZ se suele controlar para exponer la menor superficie de ataque.
 - En la práctica, la configuración de una DMZ incluye reglas muy específicas de filtrado:
 - habilitar solamente los puertos y protocolos necesarios para cada servicio
 - bloquear las conexiones directas no autorizadas previamente desde Internet hacia la red interna
 - el tráfico entre la DMZ y la red internet se controla estrictamente y se permiten únicamente las comunicaciones imprescindibles
- Esta arquitectura de segmentación y filtrado es fundamental en redes que manejan servicios expuestos a redes inseguras como Internet, ya que equilibra la accesibilidad desde el exterior con la protección de los activos internos.

Diseño con 1 FW



Diseño con 2 FWs



- Los **sistemas de detección de intrusiones** (*Intrusion Detection System*, IDS) son herramientas especializadas en **monitorizar la red, capturando el tráfico que circula por puntos estratégicos, y analizarlo para detectar comportamientos sospechosos y generar alertas** para que los administradores de seguridad puedan investigar y responder a posibles incidentes.
 - Su eficacia depende en parte de su ubicación en la red y del equilibrio entre la cantidad de tráfico procesado y la profundidad del análisis a realizar.
- Los **sistemas de prevención de intrusiones** (*Intrusion Prevention System*, IPS) **actúan automáticamente bloqueando el tráfico malicioso o deteniendo conexiones sospechosas en tiempo real.**
- Como complemento a ambos, los **sistemas de gestión de eventos e información de seguridad** (*Security Information and Event Management*, SIEM) son una herramienta híbrida que **engloba la gestión de la información de seguridad y la gestión de eventos** permitiendo tener una visión centralizada del estado de seguridad, facilitar la detección de ataques complejos y mejorar la capacidad de respuesta ante incidentes.
 - Estos sistemas **recopilan, correlacionan y analizan eventos de seguridad generados por los distintos dispositivos presentes en la red** como IDSs, IPSs, cortafuegos y servidores.

- Existen dos enfoques comunes para detectar e identificar ataques:
 - **Basado en firmas:** utiliza una base de datos con patrones conocidos de ataques (firmas) para comparar el tráfico con ellas permitiendo identificar de manera rápida y eficazmente ataques previamente documentados. Sin embargo, este método es incapaz de identificar ataques nuevos o desconocidos (*zero-day*) ni aquellos que han sido diseñados deliberadamente para evitar coincidir con firmas existentes.
 - Requieren una actualización constante de su base de datos para mantener efectividad.
 - **Basado en anomalías:** se fundamenta en el análisis del comportamiento de la red, estableciendo una línea base del tráfico habitual. A partir de ella, el sistema monitoriza continuamente la red y detecta desviaciones significativas que no concuerdan con los patrones previamente observados. Esta estrategia es eficaz para identificar aquellos ataques que la detección basada en firmas no es capaz, aunque presenta un mayor índice de falsos positivos.
 - Para llevar a cabo su análisis, estos sistemas suelen emplear técnicas de inteligencia artificial, redes neuronales y/o algoritmos estadísticos → cambios legítimos en el comportamiento del tráfico (actualizaciones, eventos inusuales o picos de actividad) pueden ser interpretados como amenazas y generar alertas innecesarias. Por ello, requieren un ajuste fino constante y una buena calibración para mantener un equilibrio entre sensibilidad y precisión.

- **En una red inalámbrica el tráfico** se propaga por el aire y **puede ser captado por cualquier dispositivo dentro del alcance de la señal** → un atacante con herramientas ampliamente disponibles puede interceptar y leer el tráfico que no esté debidamente cifrado.
- **Los puntos de acceso no autorizados** pueden suponer una puerta trasera directa a la red interna, que elude los controles perimetrales como FWs y sistemas de autenticación.
 - Estos dispositivos deben considerarse elementos no legítimos y ser detectados mediante herramientas de monitoreo de redes inalámbricas.
- **El principal mecanismo de defensa** para proteger la confidencialidad del tráfico **en estas redes es el uso de cifrado.**



- Los ataques más comunes en redes inalámbricas se pueden clasificar en:
 - **Pasivos**: interceptación de las comunicaciones, el análisis de patrones de tráfico y el reconocimiento de redes disponibles.
 - **Activos**: desconexión forzosa de clientes, la generación de un punto de acceso falso, la interceptación y manipulación mediante un ataque MitM y la interferencia electromagnética.
- Además, existen ataques específicos para cada protocolo de seguridad empleado.

- Las **políticas de seguridad establecen las reglas** que deben seguir todos los usuarios, sistemas y dispositivos de una organización y **deben estar alineadas** con los **objetivos del negocio**, los **requisitos normativos** y las **buenas prácticas** del sector.
- Cada política debe ser **documentada**, **revisada periódicamente** y **comunicada** a todos los miembros de la organización **priorizando la formación y concienciación**.
- **Su supervisión y definición recaen sobre el *Chief Information Security Officer (CISO)***. Asimismo, le corresponde promover la **mejora continua** de las políticas y los procedimientos definidos, **y garantizar que se adoptan las medidas necesarias** para proteger la información y reducir el riesgo de la organización ante amenazas.

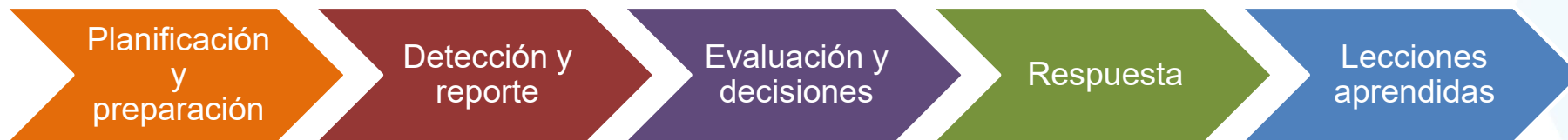
- **Control de accesos:** define quién puede acceder a qué recursos, en qué condiciones y con qué privilegios. Debe incluir principios como el mínimo privilegio, autenticación multifactor y gestión del ciclo de vida de las credenciales.
- **Uso aceptable:** establece cómo pueden emplearse los recursos informáticos de la organización, qué comportamientos están prohibidos y qué consecuencias tiene el incumplimiento.
- **Gestión de parches y actualizaciones:** detalla los procedimientos para mantener los dispositivos actualizados para subsanar vulnerabilidades conocidas.
- **Cortafuegos y segmentación de red:** establece directrices sobre la configuración de los dispositivos de seguridad perimetral y cómo segmentar la red para limitar el movimiento lateral en caso de intrusión.
- **Copias de seguridad y recuperación:** define la frecuencia, ubicación y procedimientos de respaldo, así como los mecanismos para verificar la integridad de las copias y los pasos para su restauración segura.
- **Respuesta ante incidentes:** incluye roles, responsabilidades, cadena de comunicación y los pasos a seguir en caso de un incidente de seguridad. Está estrechamente relacionada con la siguiente.
- **Plan de contingencia y continuidad de negocio:** define cómo la organización continuará operando frente a interrupciones críticas e incluye análisis del impacto, estrategias de recuperación, responsables y recursos necesarios.

- La gestión de incidentes y eventos de seguridad es un tema crítico en una organización actualmente y debe registrarse por **protocolos formalizados** que garanticen una actuación **rápida, coherente y coordinada** ante cualquier evento que comprometa sus activos.
- Las normas más habituales son el ISO/IEC 27035, el NIST 800-61 Rev. 2 y la reciente Rev. 3.

NIST SP 800-61 Rev. 2



ISO/IEC 27035-1



Planificar la gestión de incidentes de (ciber)seguridad,

incluidas las políticas, los planes y procedimientos, el apoyo técnico, la formación y concienciación, ...

Detectar, analizar, informar y evaluar incidentes de seguridad y vulnerabilidades explotadas en el mismo

reconociendo de forma temprana posibles incidentes y confirmando su naturaleza empleando las evidencias y los indicadores de compromiso procedentes de diversas fuentes y clasificando el tipo de incidente mediante un marco de referencia como la matriz MITRE ATT&CK.

Contener, mitigar y recuperar la

operativa de la organización tras el incidente de seguridad incluida la comunicación del incidente a las partes interesadas.

Aprender de los incidentes de seguridad y las vulnerabilidades empleadas en el

mismo para realizar mejoras en el sistema de gestión de la seguridad de la organización.

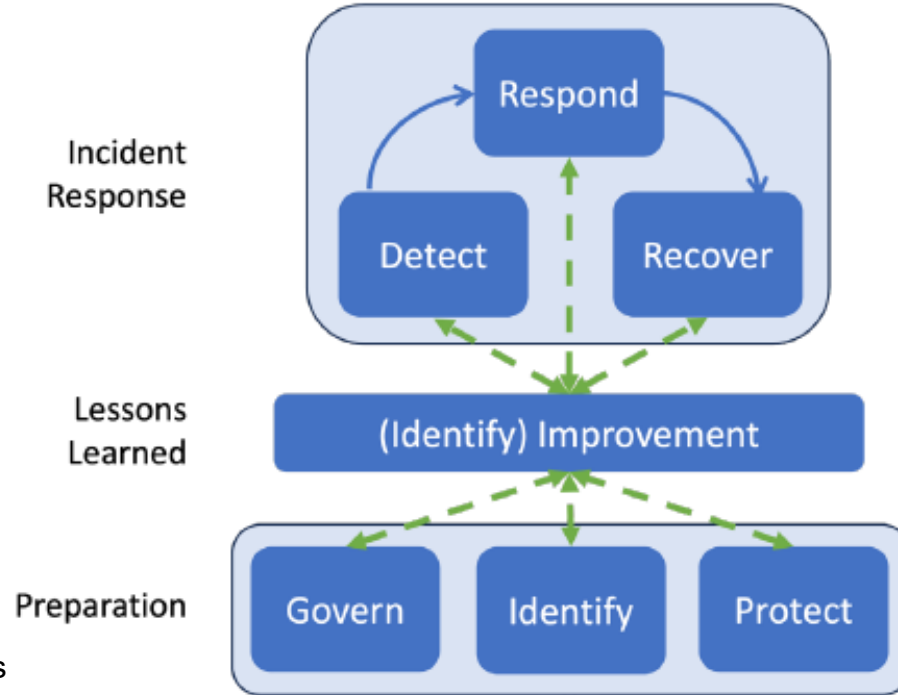
Gobernar (GV): establece, comunica y supervisa la estrategia de ciberseguridad, alineándola con la gestión de riesgos de la organización. Asimismo, asigna roles y responsabilidades y supervisa que todo se cumpla.

Identificar (ID): conocer los riesgos actuales

comprendiendo sus activos y las relaciones con otras organizaciones e incluye también la **identificación de mejoras** en políticas, planes, procesos, procedimientos, ...

Proteger (PR): aplica medidas de protección para gestionar los riesgos previamente identificados buscando reducir la probabilidad y el impacto de los incidentes de seguridad incluyendo medidas para aumentar la resiliencia de la infraestructura tecnológica.

NIST SP 800-61 Rev. 3 (CSF 2.0)



Detectar (DE): descubrir y analizar posibles ataques, activos comprometidos y comportamientos anómalos tratando de reducir el tiempo de descubrimiento y dando información para facilitar el éxito de la recuperación.

Responder (RS): acciones que se realizan con el objetivo de contener el incidente y reducir su impacto global incluyendo la notificación y la comunicación interna y externa (si procede) y el reporte formal.

Recuperación (RC): restaura los activos y las operaciones afectadas por el incidente en el menor tiempo posible incluyendo la ejecución del plan de contingencia y continuidad de negocio, restablecer servicios y datos de forma segura, ... y nutre la mejora continua del sistema.

- La cadena de información ante incidentes de seguridad **debe estar claramente definida y documentada** dentro del plan de respuesta a incidentes de la organización **para garantizar que durante todo el ciclo de vida de un incidente exista un flujo de comunicación estructurado, trazable y alineado con las responsabilidades asignadas.**
- Una vez que los **equipos internos de respuesta** identifican, categorizan un incidente y aplican medidas de contención inmediatas, le escalan la situación al **CISO**. Este evalúa el impacto, coordina la respuesta, supervisa las acciones y gestiona la comunicación con agentes externos, como agencias reguladoras, proveedores o centros de respuesta nacionales.
 - Dependiendo de la gravedad del incidente, el CISO puede notificar el evento a la dirección, al departamento legal y, cuando corresponda, a organismos reguladores o a terceros potencialmente afectados.
- El **registro detallado de las comunicaciones y decisiones tomadas** durante el proceso **constituye un recurso valioso para auditorías y la aplicación de mejoras** en el plan de respuesta a incidentes.

- Documento unificado que **integra las medidas reactivas** frente a incidentes con las **estrategias destinadas a garantizar la preservación de los procesos esenciales** de la organización.
- **Objetivos:** mantener un nivel de servicio aceptable, minimizar el periodo de recuperación y restaurar la situación previa al incidente.
- También asegura la continuidad operativa de las funciones esenciales para minimizar el impacto sobre clientes, proveedores y la reputación institucional.

- Las evidencias digitales son cualquier dato almacenado o transmitido en formato digital que es susceptible de ser usado en procedimientos legales para probar o refutar hechos.
 - Se caracterizan por su volatilidad, su facilidad para ser alteradas, dañadas o eliminadas de forma intencionada o accidental (incluso a distancia) y su posible dispersión entre múltiples sistemas y ubicaciones.
 - Su obtención y análisis suelen requerir herramientas y metodologías especializadas.
- Pueden clasificarse según su origen en:
 - **Sistema:** registros del O.S o aplicaciones, historial de comandos, configuraciones del sistema, etc.
 - **Red:** *logs* de cortafuegos, capturas de tráfico, registros DNS, tablas NAT, etc.
 - **Almacenamiento:** archivos y directorios, bases de datos, metadatos, etc.
 - **Comunicación:** correos electrónicos, mensajería instantánea, registros de llamadas VoIP, historiales de navegación, etc.

- Su gestión implica un proceso riguroso que, normalmente, sigue estas fases:
 - **Identificación:** localización de fuentes potenciales, evaluación de relevancia, priorización por volatilidad y documentación inicial.
 - **Preservación:** creación de copias forenses *bit a bit*, cálculo de *hashes* criptográficos, aislamiento de sistemas comprometidos y registro detallado de todas las acciones.
 - **Análisis:** examen forense de las copias preservadas, correlación de eventos, reconstrucción de actividades e identificación de artefactos relevantes.
 - **Presentación:** elaboración de informes técnicos, documentación de metodologías empleadas, presentación de hallazgos y, si procede, testimonio experto.
- Durante todo este proceso es esencial mantener una **cadena de custodia** sólida **documentando en todo momento** sobre la evidencia: **quién** la ha tenido, **dónde** ha estado, **cómo ha sido almacenada** y **qué operaciones** se han realizado sobre ella.
 - Esto implica aplicar una **identificación única**, **documentar todas las transferencias** con fechas, horas y responsables, **garantizar la seguridad física** en almacenamientos controlados con protección frente a alteraciones, y **preservar la integridad digital** mediante verificación de hashes, diferenciación entre copias de trabajo y originales y **registro de accesos**.
 - Cumplir estas prácticas, alineadas con las directrices de la ISO/IEC 27037 y la RFC 3227, asegura la admisibilidad de las evidencias en un proceso judicial y también refuerza la credibilidad técnica de la investigación y la postura global de ciberseguridad de la organización.

Redes de Ordenadores

GII – IYA022

Mariano Benito